Dr. Rob van Eijk
Managing Director for Europe
Future of Privacy Forum

Dr. Matthias Artzt
Senior Legal Counsel
Deutsche Bank

Leiden Legal Tech Program

To what extent can we meet GDPR requirements with Smart Contracts?

Online, 12 November 2021

Universiteit Leiden
Leiden Centre of Data Science

FUTURE OF PRIVACY FORUM

© 2021, R. van Eijk, BY-NC-SA

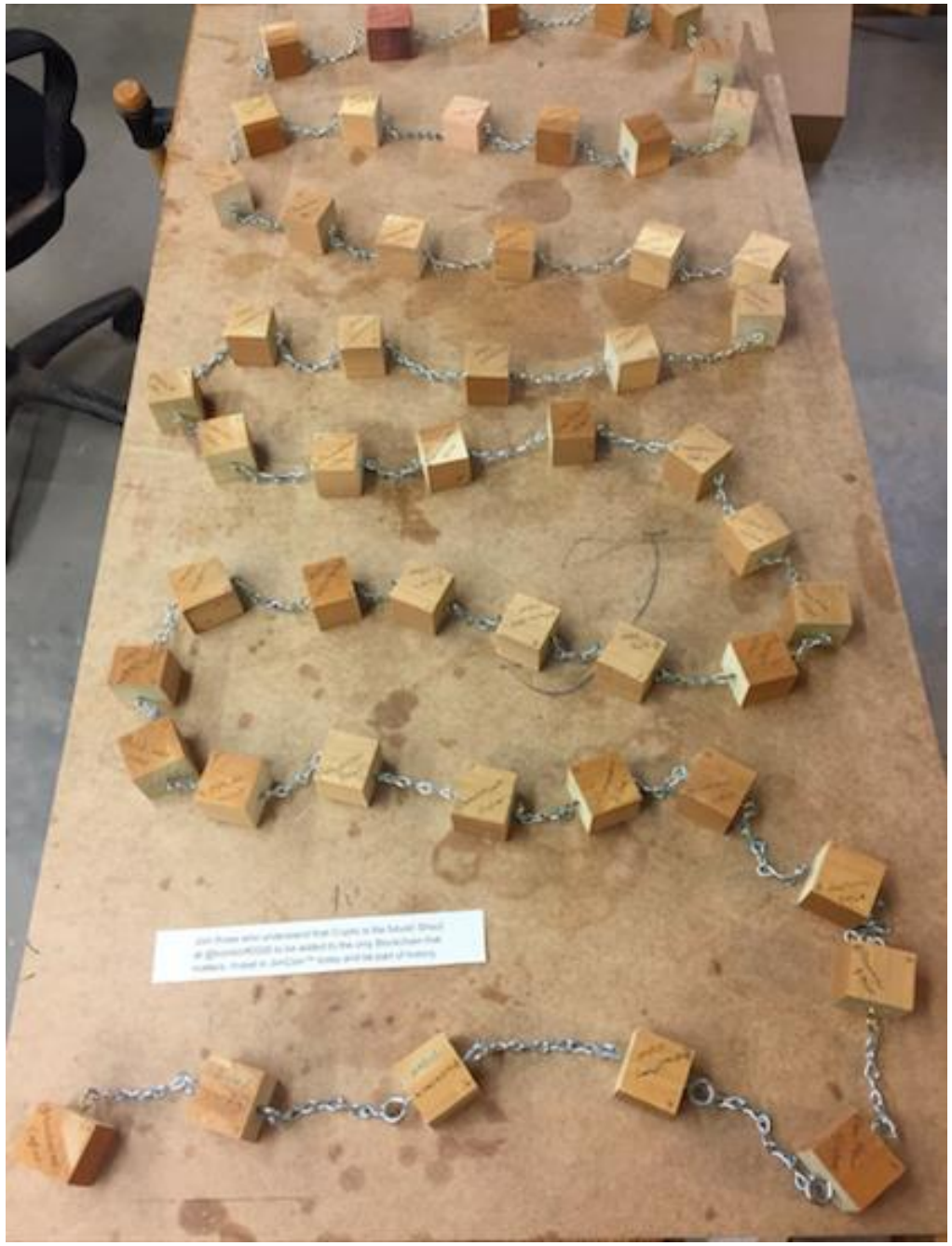
Acknowledgment

Jake van der Laan
Director, Information Technology and Regulatory Informatics,
Chief Information Officer
Financial and Consumer Services Commission
New Brunswick, Canada
jake.vanderlaan@fcnb.ca
https://www.linkedin.com/in/jakevanderlaan/

Three topics [A,B,C] and three questions

- Short recap of the block chain **[A]** and smart contract **[B]**
- GDPR aspects **[C]**:
  1. To what extent is it possible to meet the requirements of the GDPR?
  2. To what extent can you build in support for, e.g, pseudonymization, access requests, forget me requests or even explanation of decisions given the de-centralized design of block chain technology and immutability of stored information?
  3. How do you ensure that Smart Contracts and Registers in the Blockchain meet the requirements of the GDPR?

RECAP: What is “blockchain”?



A blockchain in one sentence

An “append-only transaction log”

metmuseum.org

Buy Tickets | Become a Member | Make a Donation

THE MET 150 | Visit | What's on | Art | Learn with us | Shop | Search

< Browse the Collection

Proto-Cuneiform tablet with seal impressions: administrative account of barley distribution with cylinder seal impression of a male figure, hunting dogs, and boars

ca. 3100–2900 B.C.

Sumerian

Of the many legacies left by the ancient civilizations of southern Mesopotamia, the invention of writing is paramount. At the end of the fourth millennium B.C., written language developed in the region, first as pictographs and then evolving into abstract forms called cuneiform. The pictographs, like the ones on this tablet, are called proto-cuneiform and were drawn in the clay with a pointed implement. Circular impressions alongside the pictographs represented numerical symbols. Cuneiform (meaning wedge-shaped) script was written by pressing a reed pen or stylus with a wedge-shaped tip into a clay tablet. Clay, when dried to a somewhat hardened state, made a fine surface for writing, and when fired the records written on it became permanent.

Early writing was used primarily as a means of recording and storing economic information. This tablet most likely documents grain distributed by a large temple, although the absence of verbs in early texts makes them difficult to interpret with certainty. In addition to the writing that appears on this tablet, the imagery of the cylinder seal,

Public Domain

obverse

Ledger

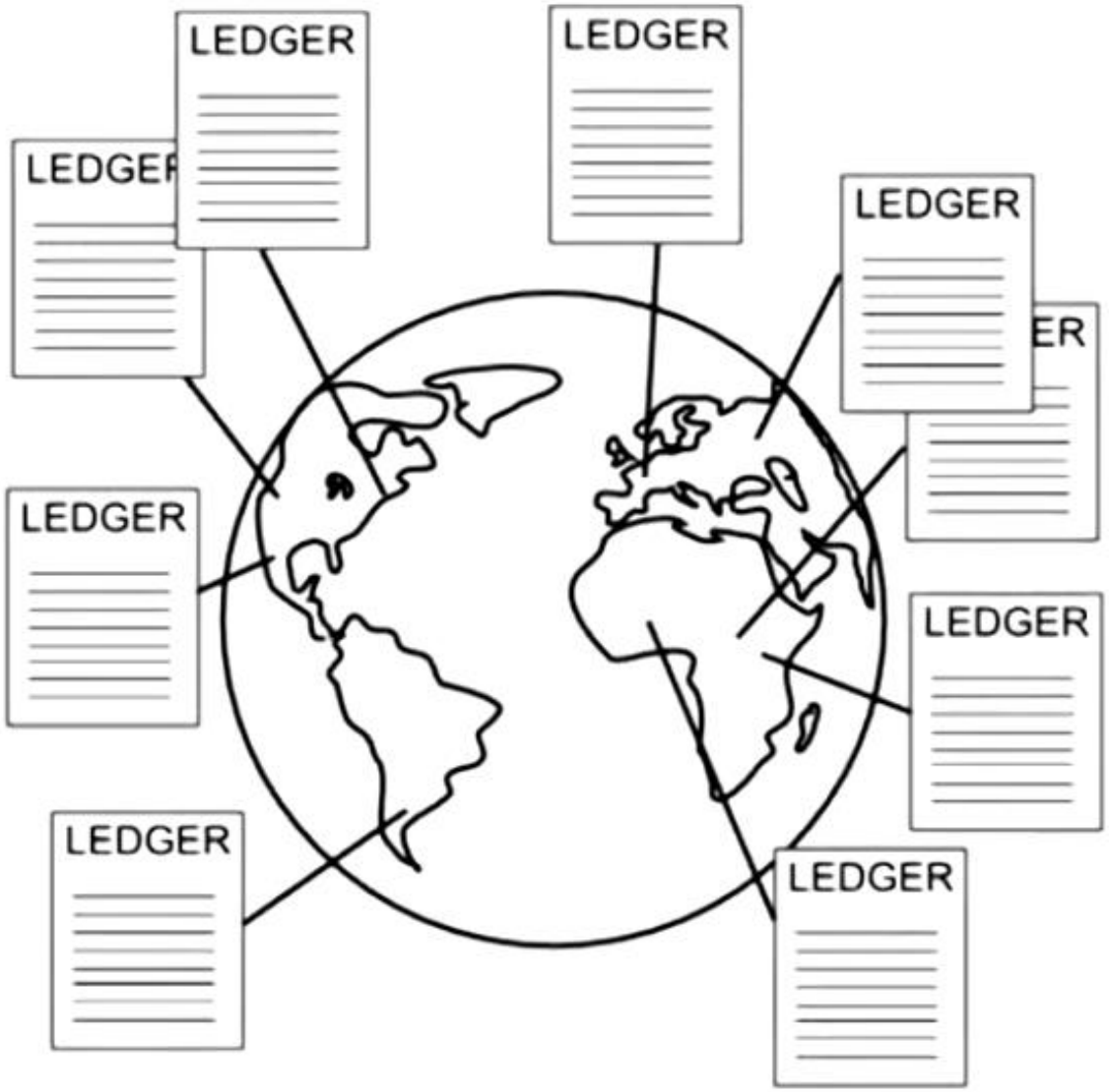
FIRST BANK OF WIKI
1425 JAMES ST, PO BOX 4000
VICTORIA BC V8X 3X4 1-800-555-5555

CHEQUING ACCOUNT STATEMENT
Page : 1 of 1

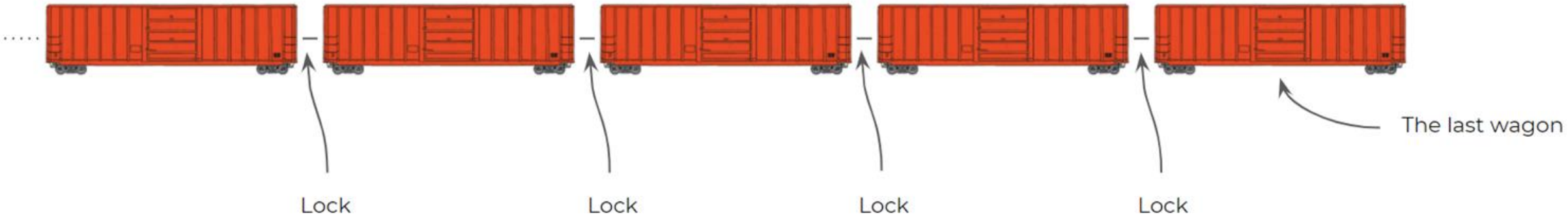
JOHN JONES
1643 DUNDAS ST W APT 27
TORONTO ON M6K 1V2

Statement period	Account No.
2003-10-09 to 2003-11-08	00005-123-456-7

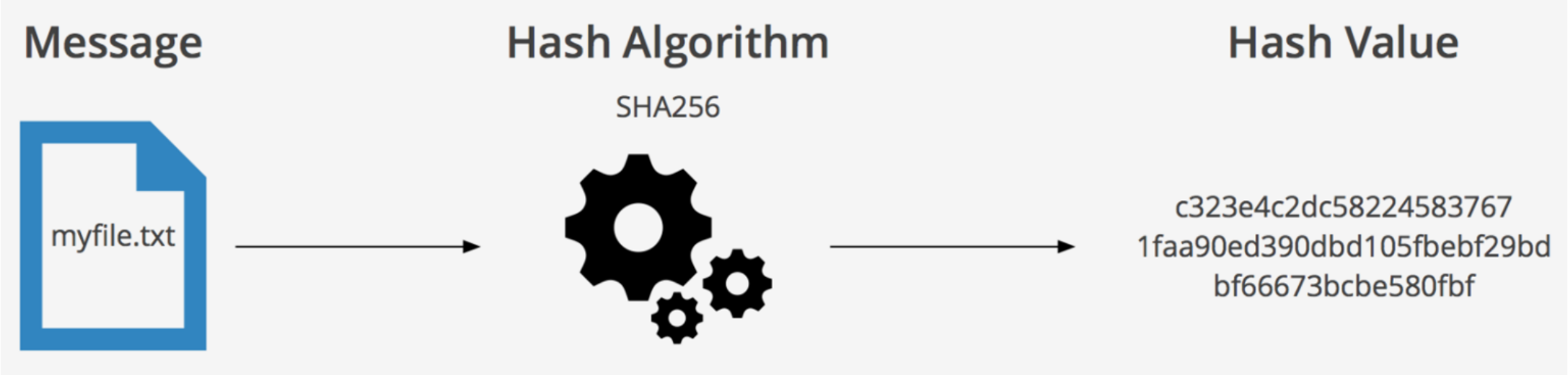
Date	Description	Ref.	Withdrawals	Deposits	Balance
2003-10-08	Previous balance				0.55
2003-10-14	Payroll Deposit - HOTEL			694.81	695.36
2003-10-14	Web Bill Payment - MASTERCARD	9685	200.00		495.36
2003-10-16	ATM Withdrawal - INTERAC	3990	21.25		474.11
2003-10-16	Fees - Interac		1.50		472.61
2003-10-20	Interac Purchase - ELECTRONICS	1975	2.99		469.62
2003-10-21	Web Bill Payment - AMEX	3314	300.00		169.62
2003-10-22	ATM Withdrawal - FIRST BANK	0064	100.00		69.62
2003-10-23	Interac Purchase - SUPERMARKET	1559	29.08		40.54
2003-10-24	Interac Refund - ELECTRONICS	1975		2.99	43.53
2003-10-27	Telephone Bill Payment - VISA	2475	6.77		36.76
2003-10-28	Payroll Deposit - HOTEL			694.81	731.57
2003-10-30	Web Funds Transfer - From SAVINGS	2620		50.00	781.57
2003-11-03	Pre-Auth. Payment - INSURANCE		33.55		748.02
2003-11-03	Cheque No. - 409		100.00		648.02
2003-11-06	Mortgage Payment		710.49		-62.47
2003-11-07	Fees - Overdraft		5.00		-67.47
2003-11-08	Fees - Monthly		5.00		-72.47
	*** Totals ***		1,515.63	1,442.61	


LEDGER
LEDGER
LEDGER
LEDGER
LEDGER
LEDGER
LEDGER
LEDGER
LEDGER

Append-only transaction log


Lock
Lock
Lock
Lock
The last wagon

Cryptographic hash function



Cryptographic hash function properties

- Every unique input has a unique output (it's a *signature*)
- It is not possible to "reverse engineer" the input from the output

Input		Digest
Rhino	→ cryptographic hash function →	0BD2 6C7D 2CDB FE3D 79A9 FD8E EE82 90B1 FB99 BB41
The white rhino runs into the hungry hippo	→ cryptographic hash function →	7D1B 91C0 F8BA CC25 8FCB CBA3 9D42 4FB4 1B67 C696
The white rhino runs imto the hungry hippo	→ cryptographic hash function →	F04D 825D FFE4 77C6 662B 82FA BB8D 8A6C 72EA D091
The white rhino runs int the hungry hippo	→ cryptographic hash function →	22EC F97C DB2C 0488 91DC A544 EC82 4F8C 21B4 1337

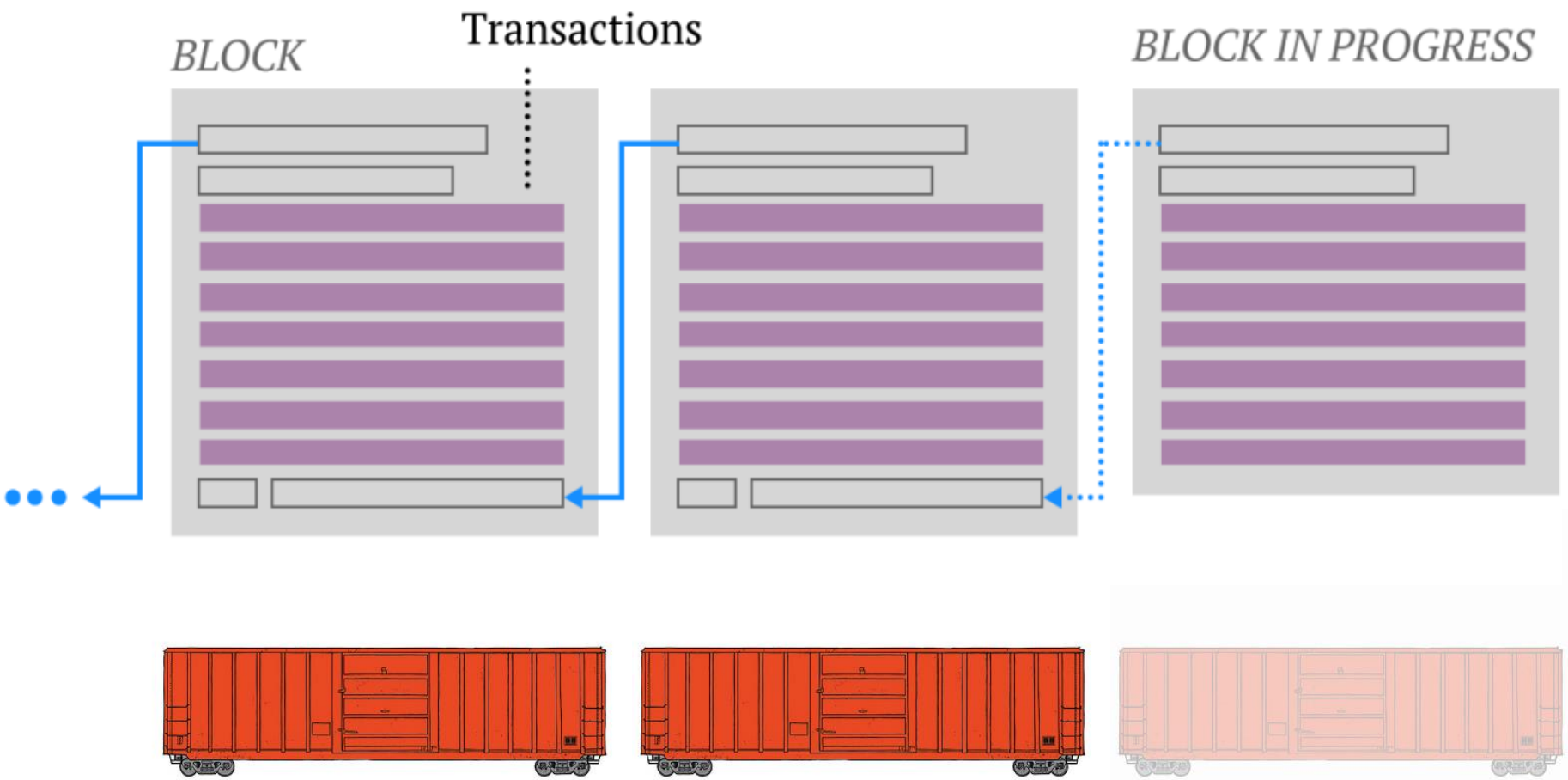
A sample SHA-256 hash digest:

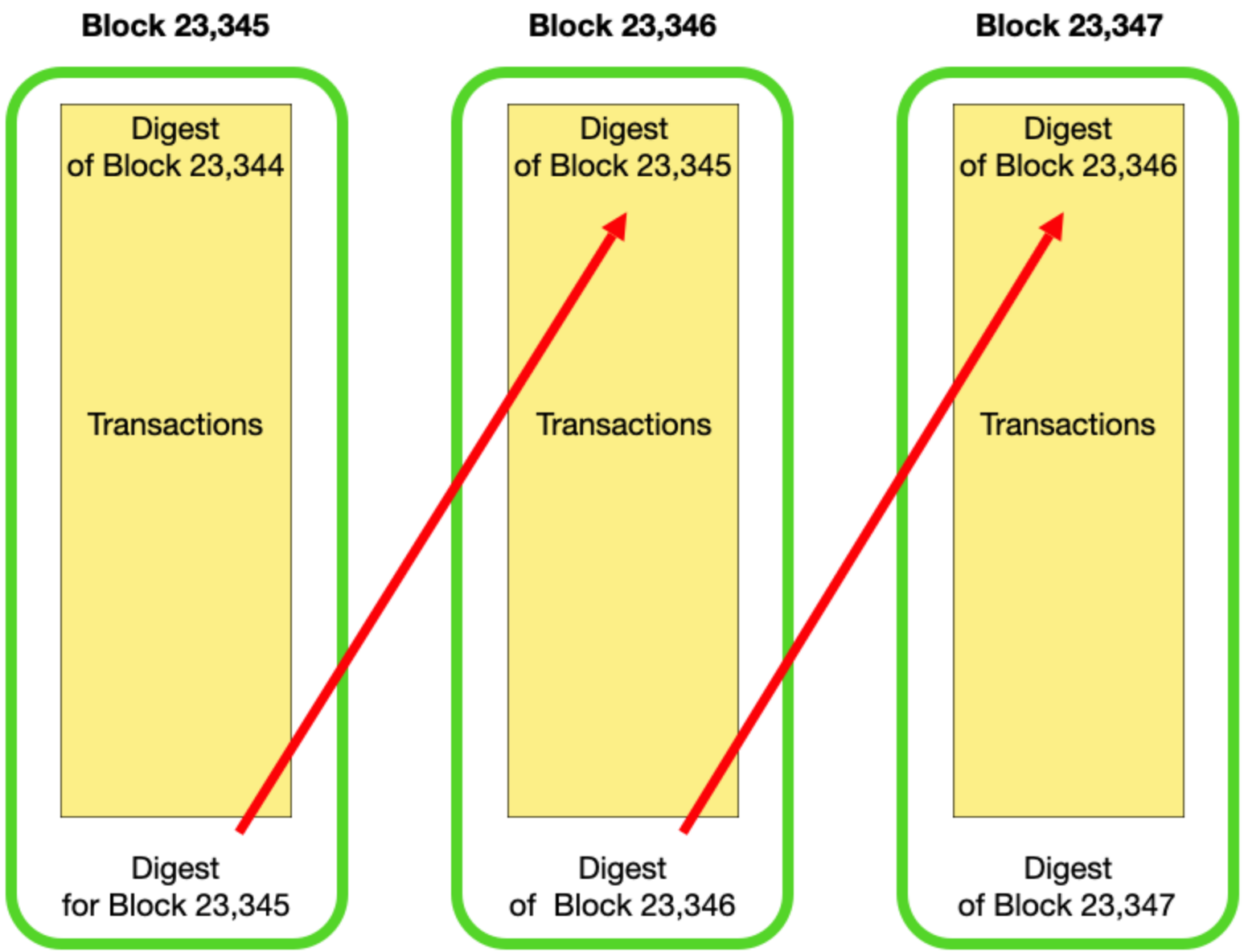
`1312af178c253f84028d480a6adc1e25e81caa44c749ec81976192e2ec934c64`

(This is really nothing more than a number between 1 and 2^256 in hexadecimal format)

How are new transactions are confirmed and added?

- The hash is very useful!!
- Confirm that files sent over the internet have not been corrupted.


BLOCK
Transactions
BLOCK IN PROGRESS


Block 23,345
Digest
of Block 23,344
Transactions
Digest
for Block 23,345
Block 23,346
Digest
of Block 23,345
Transactions
Digest
of Block 23,346
Block 23,347
Digest
of Block 23,346
Transactions
Digest
of Block 23,347

How to prevent “re-doing the whole train”?

Adding “proof of work”

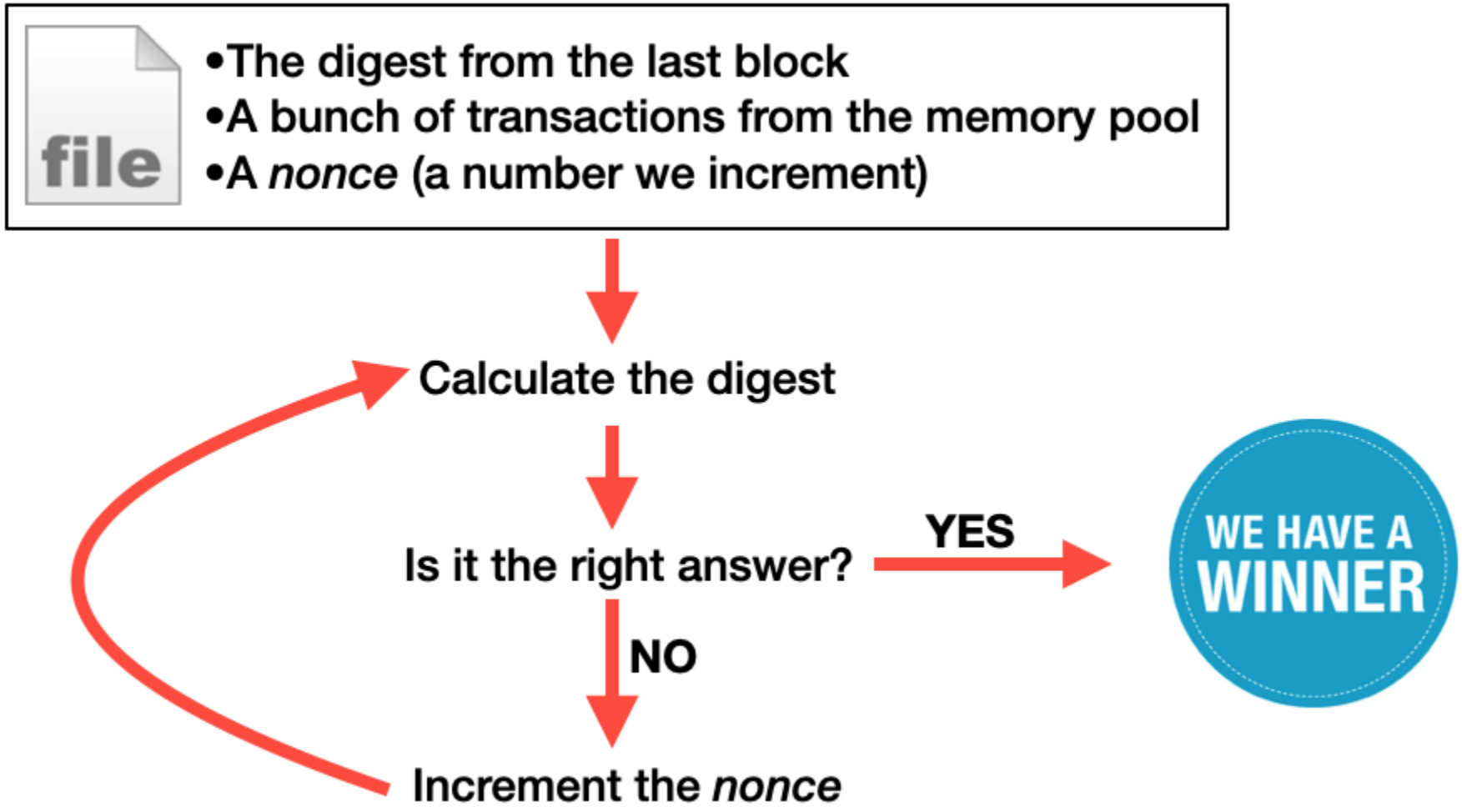
- Let’s add a ***time cost*** - impose a 10 minute delay on the addition of a new block.
- This would make re-calculation, and thus change, virtually impossible.
- How do we do this?

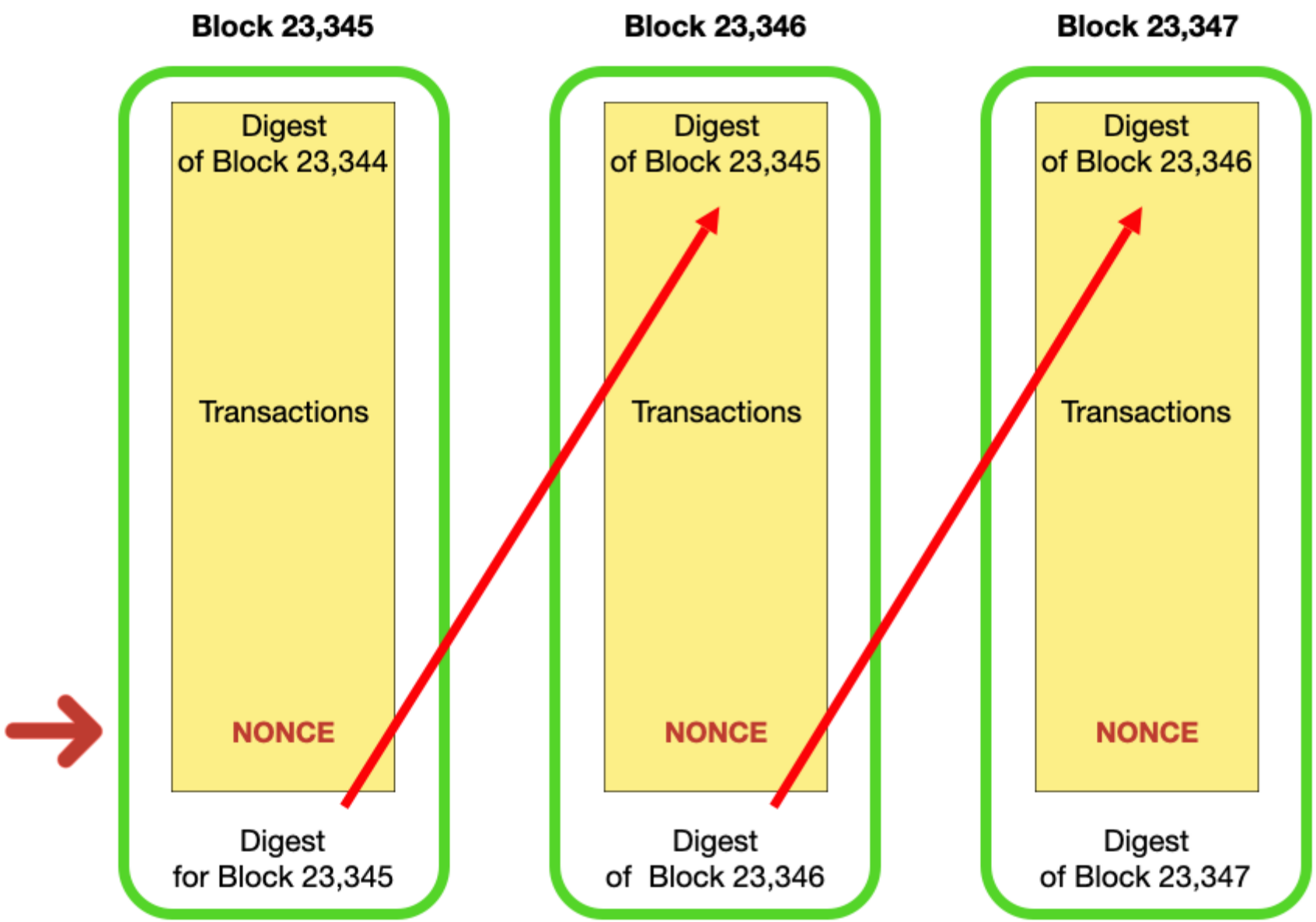
- We impose a **constraint** on the hash digest output by adding a so called **nonce**.

The type of hash we are looking for:

0000000000000000b42d99c81156d3a17228d6e1eef4139be78e948a9332a7d8

Trying different nonces: “mining”




Block 23,345
Digest
of Block 23,344
Transactions
NONCE
Digest
for Block 23,345
Block 23,346
Digest
of Block 23,345
Transactions
NONCE
Digest
of Block 23,346
Block 23,347
Digest
of Block 23,346
Transactions
NONCE
Digest
of Block 23,347

When a “winner” is found

- The winning node messages all other nodes: I found a winner!
- Other nodes verify the hash and if OK accept the new block
- Once 51% of all nodes have accepted the block, it is “confirmed”
- The winning node gets a reward (e.g., in bitcoin)
- Start all over again!

How blockchain implementations differ

- **How new transactions are confirmed and added** (consensus mechanisms):
  - Proof of Stake (e.g. Peercoin)
  - Byzantine Fault Tolerance (vote based) approaches (e.g. Ripple)
  - Directed Acyclic Graphs (e.g. Iota)
  - Proof of Elapsed Time
  - etc.

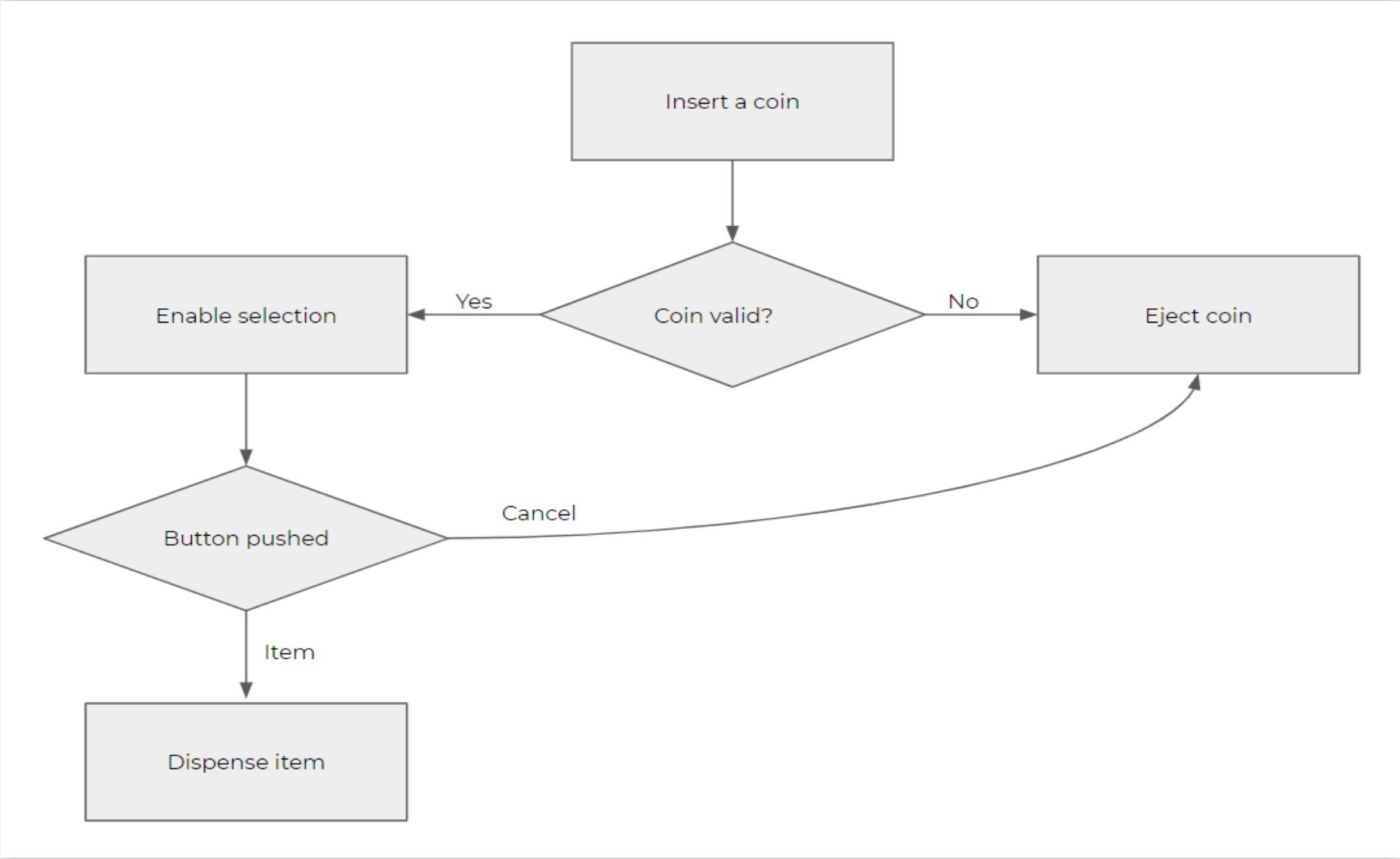
- **Who can use the blockchain**:
  - public (permissionless) blockchains
  - private (permissioned) blockchains

Ethereum features

- Tracks transactions
- Is also able to store small bits of computer code (“smart contracts”)
- Code runs within the Ethereum platform and changes the **state** of **variables** (think entitlements) stored on the blockchain
- Uses the ***ether*** cryptocurrency
- Also uses ***gas*** to pay for running the computer code
- Has a much shorter confirmation time (about 15 seconds)
- “DApps” are built on top of these platforms

“Smart” contracts

Solid State Machine Logic



Smart Contract Example [1]

```
## Late Delivery and Penalty.

In case of delayed delivery{{#if forceMajeure}} except for Force Majeure cases,{{else}} even when Force
Majeure occurs,{{/if}}
{{seller}} (the Seller) shall pay to {{buyer}} (the Buyer) for every {{penaltyDuration}}
of delay penalty amounting to {{penaltyPercentage}}% of the total value of the Equipment
whose delivery has been delayed. Any fractional part of a {{fractionalPart}} is to be
considered a full {{fractionalPart}}. The total amount of penalty shall not however,
exceed {{capPercentage}}% of the total value of the Equipment involved in late delivery.
If the delay is more than {{termination}}, the Buyer is entitled to terminate this Contract.
```

https://studio.accordproject.org/?template=ap%3A%2F%2Flatedeliveryandpenalty-else%400.3.0%23hash

Smart Contract Example [2]

Contract Data

```
1  {
2    "$class": "org.accordproject.latedeliveryandpenalty.LateDeliveryAndPenaltyContract",
3    "buyer": "resource:org.accordproject.party.Party#Steve",
4    "seller": "resource:org.accordproject.party.Party#Dan",
5    "forceMajeure": true,
6    "penaltyDuration": {
7      "$class": "org.accordproject.time.Duration",
8      "amount": 2,
9      "unit": "days"
10   },
11   "penaltyPercentage": 10.5,
12   "capPercentage": 55,
13   "termination": {
14     "$class": "org.accordproject.time.Duration",
15     "amount": 15,
16     "unit": "days"
17   },
```

Smart Contract Example [3]

```
## Late Delivery and Penalty.

In case of delayed delivery{{#if forceMajeure}} except for Force Majeure cases,{{else}} even when Force
Majeure occurs,{{/if}}
{{seller}} (the Seller) shall pay to {{buyer}} (the Buyer) for every {{penaltyDuration}}
of delay penalty amounting to {{penaltyPercentage}}% of the total value of the Equipment
whose delivery
considered a fu
exceed {{capPer
If the delay is
```

```
Late Delivery and Penalty.
----

In case of delayed delivery except for Force Majeure cases,
"Dan" (the Seller) shall pay to "Steve" (the Buyer) for every 2 days
of delay penalty amounting to 10.5% of the total value of the Equipment
whose delivery has been delayed. Any fractional part of a days is to be
considered a full days. The total amount of penalty shall not however,
exceed 55.0% of the total value of the Equipment involved in late delivery.
If the delay is more than 15 days, the Buyer is entitled to terminate this Contract.
```

Smart Contract Example [4]

Contract Data

```
1  {
2    "$class": "org.accordproject.la
3    "buyer": "resource:org.accordpr
4    "seller": "resource:org.accordp
5    "forceMajeure": true,
6    "penaltyDuration": {
7      "$class": "org.accordproject.
8      "amount": 2,
9      "unit": "days"
10   },
11   "penaltyPercentage": 10.5,
12   "capPercentage": 55,
13   "termination": {
14     "$class": "org.accordproject.
15     "amount": 15,
16     "unit": "days"
17   },
```

Contract Data

```
1  {
2    "$class": "org.accordproject.latedeliveryandpenalty.LateDeliveryAr
3    "buyer": "resource:org.accordproject.party.Party#Steve",
4    "seller": "resource:org.accordproject.party.Party#Dan",
5    "forceMajeure": false,
6    "penaltyDuration": {
7      "$class": "org.accordproject.time.Duration",
8      "amount": 2,
9      "unit": "days"
10   },
11   "penaltyPercentage": 10.5,
12   "capPercentage": 80,
13   "termination": {
14     "$class": "org.accordproject.time.Duration",
15     "amount": 15,
16     "unit": "days"
17   },
```

Smart Contract Example [5]

```
## Late Delivery and Penalty.

In case of delayed delivery{{#if forceMajeure}} except for Force Majeure cases,{{else}} even when Force
Majeure occur
{{seller}} (t
of delay pena
whose deliver
considered a
exceed {{capP
If the delay
```

```
Late Delivery and Penalty.
----

In case of delayed delivery except for Force Majeure cases,
"Dan" (the S
of delay pen
whose delive
considered a
exceed 55.0%
If the delay
```

```
Late Delivery and Penalty.
----

In case of delayed delivery even when Force Majeure occurs,
"Dan" (the Seller) shall pay to "Steve" (the Buyer) for every 2 days
of delay penalty amounting to 10.5% of the total value of the Equipment
whose delivery has been delayed. Any fractional part of a days is to be
considered a full days. The total amount of penalty shall not however,
exceed 80.0% of the total value of the Equipment involved in late delivery.
If the delay is more than 15 days, the Buyer is entitled to terminate this
```

Smart Contract Example [6]

```
## Late Delivery and Penalty.

In case of delayed delivery{{#if forceMajeure}} except for Force Majeure cases,{{else}} even when Force
Majeure occur
{{seller}} (t
of delay pena
whose deliver
considered a
exceed {{capP
If the delay
```

```
Late Delivery and Penalty.
----

In case
"Dan"
of del
whose
considered a
exceed 55.0%
If the delay
```

```
enforce !contract.forceMajeure or !request.forceMajeure else
return LateDeliveryAndPenaltyResponse{
  penalty: 0.0,
  buyerMayTerminate: true
}
```

```
In case of delayed delivery even when Force Majeure occurs,
"Dan" (the Seller) shall pay to "Steve" (the Buyer) for every 2 days
of delay penalty amounting to 10.5% of the total value of the Equipment
whose delivery has been delayed. Any fractional part of a days is to be
considered a full days. The total amount of penalty shall not however,
exceed 80.0% of the total value of the Equipment involved in late delivery.
If the delay is more than 15 days, the Buyer is entitled to terminate this
```

GDPR Aspects (1/2)

1. Allocation of roles and responibilities under the GDPR
2. Data subject rights under the GDPR
3. Principles of purpose limitation and data minimization vs blockchain finality
4. Techniques to mitigate data protection risks

GDPR Aspects (2/2)

5 Privacy by Design

6 Legal grounds under the GDPR

7 Key Take aways

1. Allocation of roles and responsibilities (1/4)

1. **Exhaustive list of roles under the GDPR**:
   - **(Joint) controller, Art. 4 (7), Art. 26**: „natural or legal person (…) which, alone or jointly with others, determines the purposes and means of the processing of personal data (…)“ > ***similar to „business“ under CCPA***
   - **Processor, Art. 4 (8)**: „natural or legal person (…) which processes personal data on behalf of the controller“ > ***similar to „service provider“ under CCPA***
2. **The usual players in a blockchain environment:**
   - Miners
   - Nodes
   - Wallets
   - Users
   - Developers of smart contracts
   - Oracles
   - Governance bodies

1. Allocation of roles and responsibilities (2/4)

3. Users

- **Definition:**
  - **Participate in any transaction in a blockchain network** provided that such transaction stores or processes personal data
  - CNIL: User = controller when (i) the user is a **natural person**; and (ii) the processing is related to a **professional or commercial activity**; or, when the user is a **legal person that submitts personal data to a blockchain**
  - EU Blockchain Observatory: User = controller when the user submitts personal data to the blockchain as part of his business activity
- **Legal implication:**
  - **Delineation from the household exemption** of Art. 2 (2c) of the GDPR ►household/private activity ►GDPR doesn´t apply ► user ≠ controller

1. Allocation of roles and responsibilities (3/4)

4. Developers of smart contracts

- **Definition:**
  - **Smart contract is a piece of software that, once deployed to a blockchain network, may be executed independently from their developer** when called by a blockchain user
  - Developer creates an algorithm to be built in the software

- **Legal implication:**
  - CNIL: Developer has no role to play unless he intervenes in the data processing actively
  - Developer **only provide a software solution to blockchain users** and don´t operate that software while blockchain users write personal data to the blockchain leveraging the algorithm of the smart contract
  - Developer ≠ controller ≠ processor

1. Allocation of roles and responsibilities (4/4)

5. Oracles

- **Definition:**
  - Oracles are agents that **allow the transfer of external data feeds to the blockchain** leveraging smart contracts
  - Necessary to process external real-world events to be inputted onto the blockchain for further usage
  - Oracles have a strong influence on the data processing operation and its result carried out by the smart contract algorithm

- **Legal implication:**
  - Oracles = controller if they have a **commercial interest in the related data processing and the outcome** of that data processing activity
  - Requires case-by-case consideration
  - Rule of thumb: Oracles belong to blockchain infrastructure

2. Data subject rights under the GDPR (1/4)

1. How do data subject rights (DSR) apply to the blockchain?

a) Applicability of the GDPR

- Once one block contains personal data and the block is added to the blockchain ► **storage = data processing pursuant to Art. 4 sec. 2 of the GDPR**
- Data subject may exercise his rights pursuant to Art. 15 – 22 of the GDPR. **Problem: against whom?**

b) Distinction between public and private blockchains in relation to enforcing data subject rights

- Private blockchains: Governance body to be the first choice to address any data subject rights. Joint controllers according to Art. 26 of the GDPR
- Public blockchains: Data subjects face a challenge to (i) identify the controller, and to (ii) get the controller to carry out his obligations

2. Data subject rights under the GDPR (2/4)

2. Factual enforceability of particular DSRs

a) Right to access personal data, Art. 15 GDPR

- Basic right: prerequisite for the exercise of any other right under the GDPR
- Necessary to understand which data is being processed and for what purpose
- **Problem:** In a public blockchain **a controller, once identified, is factually unable to access data** submitted to the blockchain: data is typically encrypted or hashed; impossible to determine whether the related data is personal and relates to the data subject concerned

b) Right to rectify personal data, Art. 16 GDPR

- Right to request rectification of inaccurate personal data and to complete personal data which is incomplete
- **Problem: Impossibility to modify data** registered onto a blockchain

2. Data subject rights under the GDPR (3/4)

c) Right to erasure („right to be forgotten“), Art. 17 GDPR

- **What does erasure mean?**
  - Data subject may request the erasure of his/her personal data provided one of the conditions set out in Art. 17 sec. 1 GDPR applies
  - **Erasure as a legal term is defined very broadly** (e.g. expunge, overwriting, making data unusable)
  - **<u>Problem:</u> Impossibility to delete data** once registered onto the blockchain
  - <u>But:</u> This is not a Catch 22 situation since alternative solutions are permissible when the erasure is virtually not viable ►see *techniques to mitigate data protection risks*

2. Data subject rights under the GDPR (4/4)

3. Processing of DSR requests via smart contracts

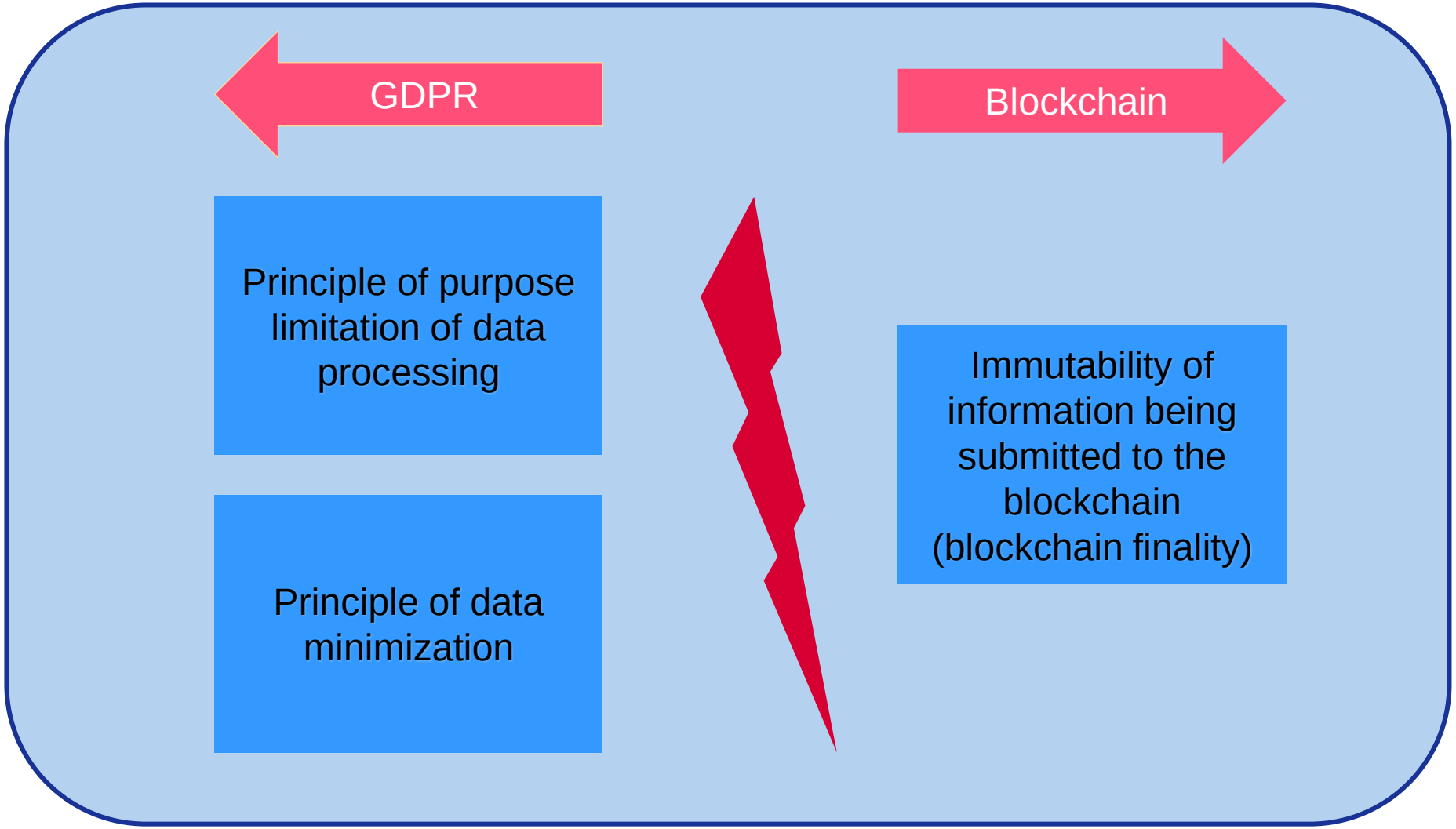
a) Right to access personal data

- Access request is an **event outside the blockchain**
- **Oracle transfers such request to the blockchain** to be processed by means of smart contract algorithm
- **Smart contract automates the execution** of the information flow to the related data subject

b) Right to rectify and erase personal data

- Request transmitted through an oracle
- Execution of request can be automated by using a smart contract algorithm
- **<u>Problem:</u> Impossibility to modify or delete data** registered onto a blockchain due to blockchain finality
- **Hashing out via smart contract** feasible ►see *techniques to mitigate data protection risks*

3. Principles of purpose limitation and data minimization vs blockchain finality (1/3)



3. Principles of purpose limitation and data minimization vs blockchain finality (2/3)

1. Principle of purpose limitation

- **Definition:**
  - "Personal data shall be collected for specific, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes" (Art. 5 sec. 1b GDPR) and "A business shall not (…) use personal information collected for additional purposes without providing the consumer with notice consistent with this section" (sec. 1798.100 (b) CCPA)
  - Purpose limitation is the "cornerstone of data protection" (Art. 29 Data Protection Working Party [now: EDPB])
- **Legal implication on blockchain:**
  - Blockchain, by nature, continuously processes data by storing it onto the blockchain which also includes legacy personal data (data which is not needed any more, e.g. after completion of a particular transaction)

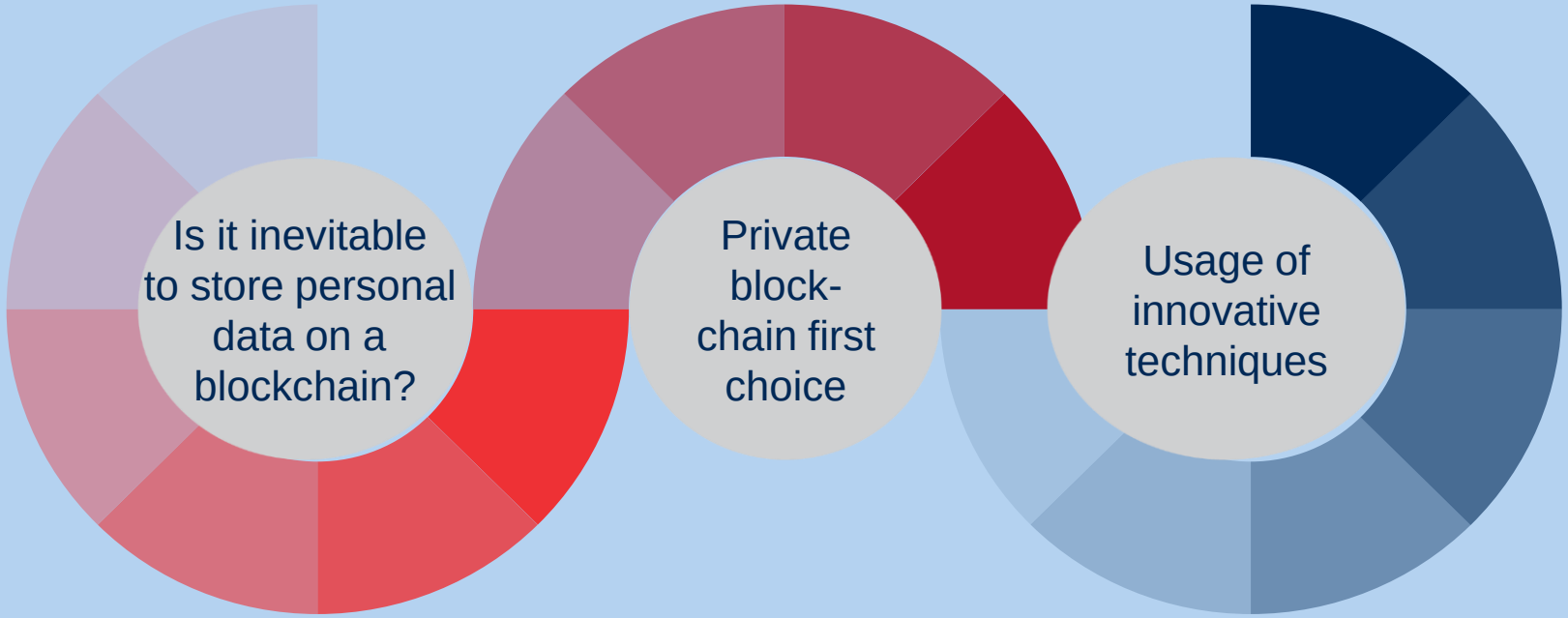
3. Principles of purpose limitation and data minimization vs blockchain finality (3/3)

2. Principle of data minimization

- **Definition:**
  - Only those data which is necessary to meet the purpose determined by the controller must be collected and processed
  - Period for which the personal data is being stored must be limited to a strict minimum (Recital 39 of the GDPR)
- **Legal implication on blockchain:**
  - Blockchain artefacts clash with the data minimization principle:
    ► Ever-growing nature of databases containing personal data
    ► Replication of data in a blockchain network where each node stores a full copy of the database
  - <u>But:</u> smart contract algorithm or oracles may determine what data is being stored in order to ensure data minimization

4. Techniques to mitigate data protection risks (1/5)

Assessment of the permissibility of submitting personal data to the blockchain:



4. Techniques to mitigate data protection risks (2/5)

- **Big picture:** How is the data being processed and is there any need to store it on a blockchain? Offchain storage should be the first choice
- **Usage of private blockchains as primary objective**
- **Usage of innovative encryption techniques**, particularly with regard to public blockchains:
  - **Anonymization** as primary approach
  - If anonymization is not doable, **state-of-the-art encryption, particularly hashing**
  - Please note: Hashing is an encryption technique and does not entail anonymization ► Hashing does not turn personal data into non personal data ► GDPR applies

4. Techniques to mitigate data protection risks (3/5)

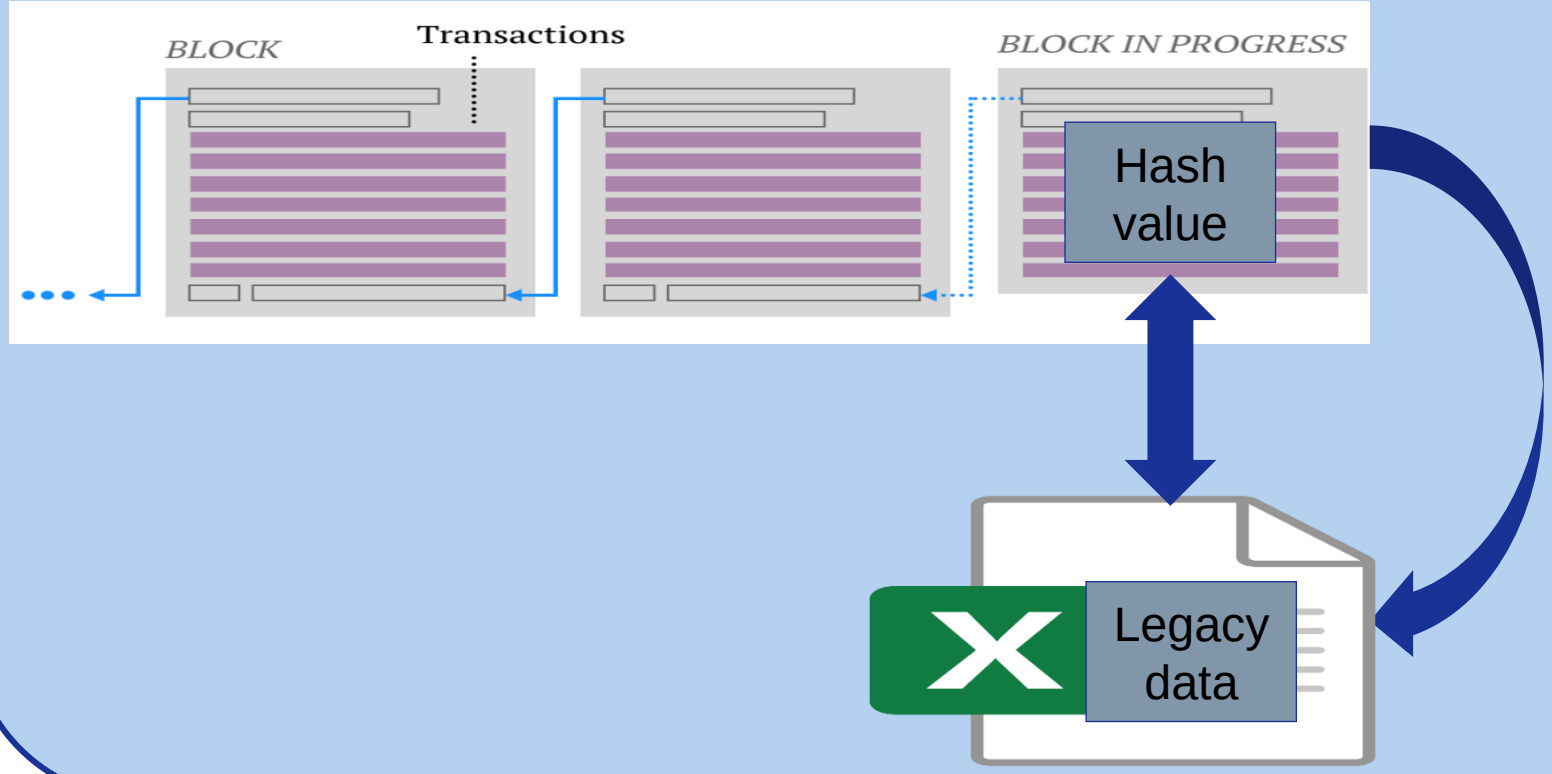
Usage of interoperable blockchains („multi-layered”)

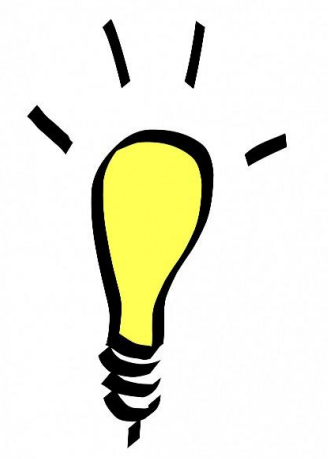
Private

Public

4. Techniques to mitigate data protection risks (4/5)

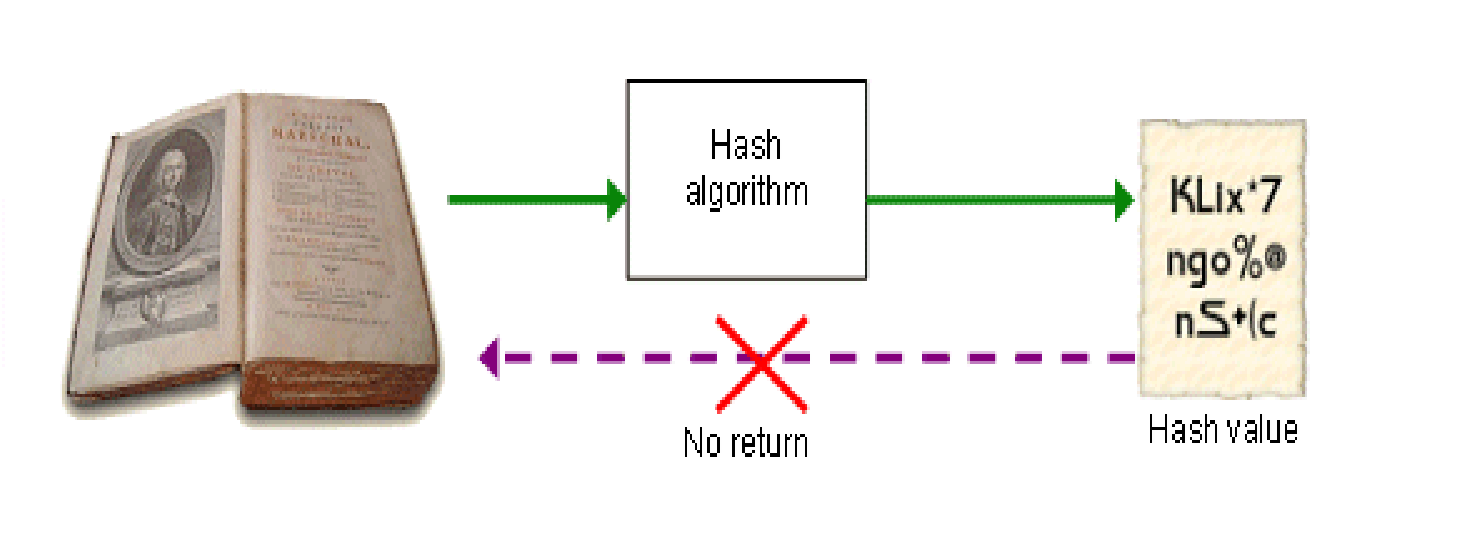
Off-chain storage and hashing of legacy data („hashing-out")





4. Techniques to mitigate data protection risks (5/5)

- **Erasure of personal data by deleting off-chain legacy data**
  - **Hashing-out and deleting legacy data comply with an erasure request** even though the hash of the personal data remains on the blockchain; **hashing out** throughout smart contract algorithm, but **deletion** of data stored off-chain requires human intervention



5. Privacy by Design

1. Definition and impact on controllers

- **Art. 25 GDPR specifically requires controllers to establish appropriate technical and organizational measures** to implement data protection principles and to safeguard the rights of data subjects
  ► Controller must **choose that technology from the outset with the least impact on the rights of data subjects**
  ► Privacy considerations must be factored in at the earliest possible stage
  ► Controller has to **implement measures to ensure minimization of the data to be processed as well as security** (e.g. pseudonymization, encryption)

2. Privacy by Design and smart contracts?

- Smart contract algorithm can ascertain data minimization and technical safeguards

6. Legal grounds under the GDPR

1. **Contractual necessity, Art. 6 (1)(b) GDPR**
   - Processing necessary for the performance of a contract
   - Relevant regarding smart contracts
2. **Consent, Art. 6 (1)(a) GDPR**
   - Data subject has given consent to the processing of his or her data for one or more specific purposes
   - Consent can be withdrawn by the data subject at any time
   - Unclear to whom the user must give consent in a blockchain context
3. **Legitimate interest, Art. 6 (1)(f) GDPR**
   - Processing necessary for the purposes of the legitimate interests pursued by the controller or by a third party
   - Submitting of personal data to a blockchain is legitimate if, e.g., the processing activity aims to prevent frauds (Recital 47 of the GDPR)
4. **Compliance with legal obligation, Art. 6 (1)(c) GDPR and public interest, Art. 6 (1)(e) GDPR**

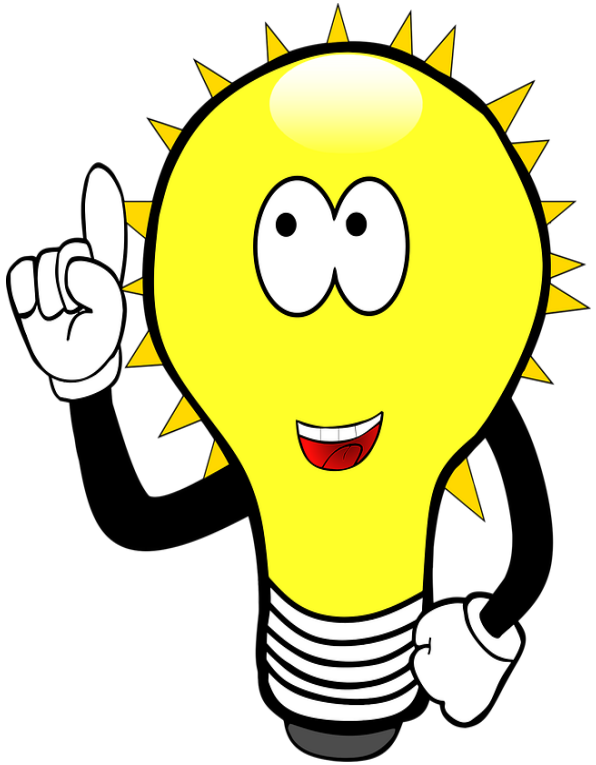
7. Key Take Aways

It is just technology

GDPR is designed to be technology neutral

Tensions with GDPR can be overcome

Usage of state-of-the-art encryption is key

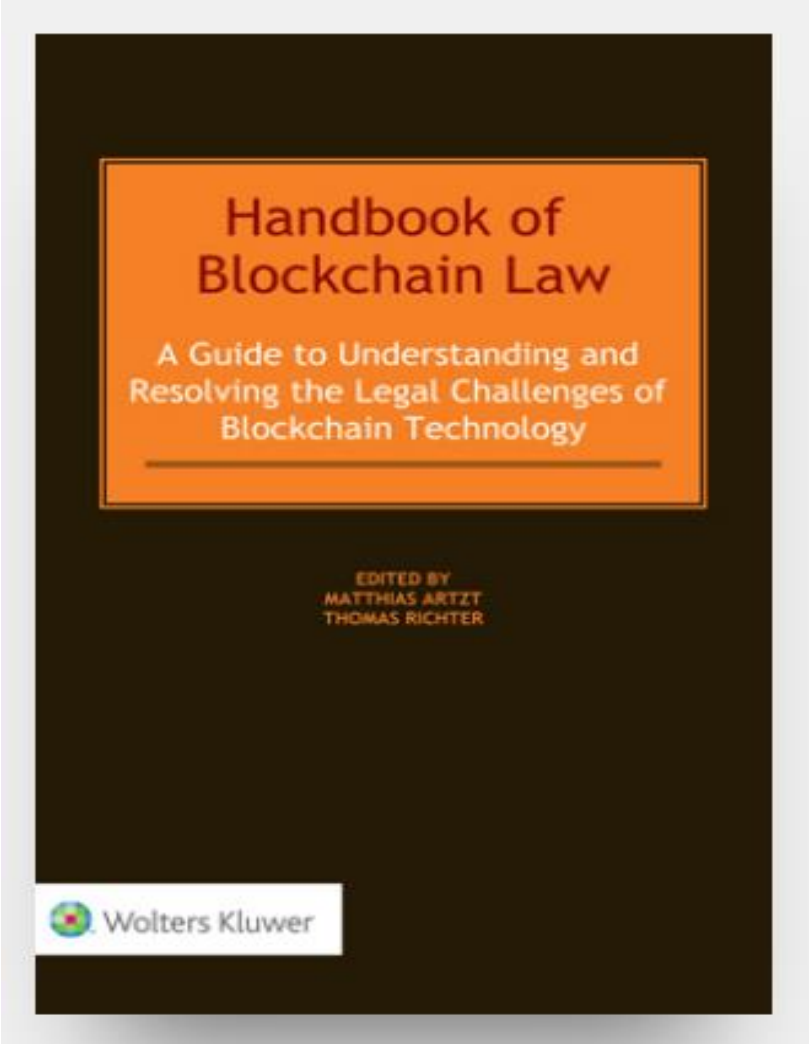


Consider Privacy by Design

Private blockchain first

Track guidance of data protection authorities

Thank you for your attention!



Group Discussion

- To what extent is it possible to meet the requirements of the GDPR?
- To what extent can you build in support for, e.g, pseudonymization, access requests, forget me requests or even explanation of decisions given the de-centralized design of block chain technology and immutability of stored information?
- How do you ensure that Smart Contracts and Registers in the Blockchain meet the requirements of the GDPR?

Contact:

rvaneijk@fpf.org
matthias.artzt@db.com